

norm

NEN-EN 40000-1-2

Cybersecurity requirements for products with digital elements - Part 1-2: Principles for cyber resilience

Publicatie uitsluitend voor commentaar

oktober 2025

ICS 35.030

Commentaar vóór 2025-12-01

Als Europees normontwerp is gepubliceerd: prEN 40000-1-2:2025, IDT

Definitief vastgestelde normen zullen als Nederlandse norm gelden. Daarom wordt dit normontwerp in Nederland voor commentaar gepubliceerd. Op het ontwerp ingebracht commentaar zal aan de bevoegde normcommissie worden voorgelegd die hiermee rekening zal houden bij de bepaling van de Nederlandse stem. Indien er geen bezwaar bij NEN wordt gebracht, kan dat leiden tot ongewijzigde definitieve vaststelling van het ontwerp als norm.

Van Europese normen bestaan drie officiële versies: Engels, Frans en Duits. Voor Nederland zal de Engelse versie gelden. Daarnaast kan er gekozen worden voor een andere geautoriseerde versie in het Nederlands.

Normcommissie 381027 'Cybersecurity & Privacy'



THIS PUBLICATION IS COPYRIGHT PROTECTED

DEZE PUBLICATIE IS AUTEURSRECHTELIJK BESCHERMD

Apart from exceptions provided by the law, nothing from this publication may be duplicated and/or published by means of photocopy, microfilm, storage in computer files or otherwise, which also applies to full or partial processing, without the written consent of Stichting Koninklijk Nederlands Normalisatie Instituut.

Stichting Koninklijk Nederlands Normalisatie Instituut shall, with the exclusion of any other beneficiary, collect payments owed by third parties for duplication and/or act in and out of law, where this authority is not transferred or falls by right to Stichting Reprerecht.

Auteursrecht voorbehouden. Behoudens uitzondering door de wet gesteld mag zonder schriftelijke toestemming van Stichting Koninklijk Nederlands Normalisatie Instituut niets uit deze uitgave worden verveelvoudigd en/of openbaar gemaakt door middel van fotokopie, microfilm, opslag in computerbestanden of anderszins, hetgeen ook van toepassing is op gehele of gedeeltelijke bewerking.

Stichting Koninklijk Nederlands Normalisatie Instituut is met uitsluiting van ieder ander gerechtigd de door derden verschuldigde vergoedingen voor verveelvoudiging te innen en/of daartoe in en buiten rechte op te treden, voor zover deze bevoegdheid niet is overgedragen c.q. rechtens toekomt aan Stichting Reprerecht.

Although the utmost care has been taken with this publication, errors and omissions cannot be entirely excluded. Stichting Koninklijk Nederlands Normalisatie Instituut and/or the members of the committees therefore accept no liability, not even for direct or indirect damage, occurring due to or in relation with the application of publications issued by Stichting Koninklijk Nederlands Normalisatie Instituut.

Hoewel bij deze uitgave de uiterste zorg is nagestreefd, kunnen fouten en onvolledigheden niet geheel worden uitgesloten. Stichting Koninklijk Nederlands Normalisatie Instituut en/of de leden van de commissies aanvaarden derhalve geen enkele aansprakelijkheid, ook niet voor directe of indirecte schade, ontstaan door of verband houdend met toepassing van door Stichting Koninklijk Nederlands Normalisatie Instituut gepubliceerde uitgaven.

Ontwerp
Draft

EUROPEAN STANDARD
NORME EUROPÉENNE
EUROPÄISCHE NORM

DRAFT
prEN 40000-1-2

October 2025

ICS 35.030

English version

**Cybersecurity requirements for products with digital
elements - Part 1-2: Principles for cyber resilience**

Anforderungen an die Cybersicherheit von Produkten
mit digitalen Bestandteilen - Grundsätze für die
Cyberresilienz

This draft European Standard is submitted to CEN members for enquiry. It has been drawn up by the Technical Committee CEN/CLC/JTC 13.

If this draft becomes a European Standard, CEN and CENELEC members are bound to comply with the CEN/CENELEC Internal Regulations which stipulate the conditions for giving this European Standard the status of a national standard without any alteration.

This draft European Standard was established by CEN and CENELEC in three official versions (English, French, German). A version in any other language made by translation under the responsibility of a CEN and CENELEC member into its own language and notified to the CEN-CENELEC Management Centre has the same status as the official versions.

CEN and CENELEC members are the national standards bodies and national electrotechnical committees of Austria, Belgium, Bulgaria, Croatia, Cyprus, Czech Republic, Denmark, Estonia, Finland, France, Germany, Greece, Hungary, Iceland, Ireland, Italy, Latvia, Lithuania, Luxembourg, Malta, Netherlands, Norway, Poland, Portugal, Republic of North Macedonia, Romania, Serbia, Slovakia, Slovenia, Spain, Sweden, Switzerland, Türkiye and United Kingdom.

Recipients of this draft are invited to submit, with their comments, notification of any relevant patent rights of which they are aware and to provide supporting documentation. Recipients of this draft are invited to submit, with their comments, notification of any relevant patent rights of which they are aware and to provide supporting documentation.

Warning : This document is not a European Standard. It is distributed for review and comments. It is subject to change without notice and shall not be referred to as a European Standard.



Contents	Page
European foreword	5
1 Scope	6
2 Normative references	6
3 Terms and definitions	6
4 Introduction	6
5 Cybersecurity principles	7
5.1 General	7
5.2 Risk-based approach to cybersecurity	7
5.2.1 Principle	7
5.2.2 Guidance	7
5.3 Security by design	8
5.3.1 Principle	8
5.3.2 Guidance	8
5.4 Secure by default	9
5.4.1 Principle	9
5.4.2 Guidance	9
5.5 Transparency	9
5.5.1 Principle	9
5.5.2 Guidance	9
6 Risk management elements	10
6.1 General	10
6.2 Product context	12
6.2.1 General	12
6.2.2 Input	13
6.2.3 Requirement	14
6.2.4 Output	14
6.2.5 Assessment criteria	14
6.3 Risk acceptance criteria and risk management methodology	14
6.3.1 General	14
6.3.2 Input	16
6.3.3 Requirement	16
6.3.4 Output	16
6.3.5 Assessment criteria	16
6.4 Risk assessment	17
6.4.1 General	17
6.4.2 Asset and cybersecurity objective identification	17
6.4.3 Threat identification	18
6.4.4 Risk estimation	19
6.4.5 Risk evaluation	20
6.5 Risk treatment	21
6.5.1 General	21
6.5.2 Input	22
6.5.3 Requirement	22
6.5.4 Output	22
6.5.5 Assessment criteria	22
6.6 Risk communication	23
6.6.1 General	23
6.6.2 Input	23
6.6.3 Requirement	23
6.6.4 Output	24
6.6.5 Assessment criteria	24
6.7 Risk monitoring and review	24

6.7.1	General	24
6.7.2	Input	24
6.7.3	Requirement	24
6.7.4	Output	25
6.7.5	Assessment criteria	25
7	Cybersecurity activities	25
7.1	General	25
7.2	Product cybersecurity planning	26
7.2.1	General	26
7.2.2	Input	26
7.2.3	Requirement	26
7.2.4	Output	26
7.2.5	Assessment criteria	26
7.3	Product cybersecurity requirements	26
7.3.1	General	26
7.3.2	Input	27
7.3.3	Requirement	27
7.3.4	Output	28
7.3.5	Assessment criteria	28
7.4	Cybersecurity architecture and design	28
7.4.1	General	28
7.4.2	Input	28
7.4.3	Requirement	28
7.4.4	Output	29
7.4.5	Assessment criteria	29
7.5	Secure implementation	29
7.5.1	General	29
7.5.2	Input	30
7.5.3	Requirement	30
7.5.4	Output	30
7.5.5	Assessment criteria	30
7.6	Cybersecurity verification and validation	31
7.6.1	General	31
7.6.2	Input	32
7.6.3	Requirement	32
7.6.4	Output	33
7.6.5	Assessment criteria	33
7.7	Secure production and distribution	33
7.7.1	General	33
7.7.2	Digital production	34
7.7.3	Manufacturing	35
7.8	Cybersecurity issue management	36
7.8.1	General	36
7.8.2	Input	36
7.8.3	Requirement	36
7.8.4	Output	37
7.8.5	Assessment criteria	37
7.9	Product monitoring	37
7.9.1	General	37
7.9.2	Input	37
7.9.3	Requirement	37
7.9.4	Output	38
7.9.5	Assessment criteria	38
7.10	Planning for secure decommissioning	38
7.10.1	General	38
7.10.2	Input	38
7.10.3	Requirement	38

prEN 40000-1-2 (E)

7.10.4 Output	39
7.10.5 Assessment criteria	39
7.11 Third-party component cybersecurity management	39
7.11.1 General	39
7.11.2 Input	40
7.11.3 Requirement	40
7.11.4 Output	41
7.11.5 Assessment criteria	41
Annex A (informative) Coherence with vertical standards	42
A.1 Coherence elements	42
Annex B (informative) Example of a Cybersecurity Supplier Agreement (CSSA)	43
B.1 General	43
B.2 CSSA example	44
Annex C (informative) Relationship between this European Standard and the essential cybersecurity requirements of Regulation (EU) 2024/2847	48
C.1 General	48
C.2 Reference to essential requirements	48
C.3 Mapping to essential requirements	48
C.4 Normative or informative	51
C.5 Assessment criteria	52
Annex D (informative) Accessible and inclusive cybersecurity	53
D.1 Scope	53
D.2 Legal reasoning	53
D.3 The user	53
D.4 Nature of the required interaction	54
D.5 Consequences of the interaction method on the user's cybersecurity	54
D.6 Recommended solution to ensure maximum cybersecurity to the potential users	54
D.7 Communication with the user	55
Bibliography	56

European foreword

This document (prEN 40000-1-2:2025) has been prepared by Technical Committee CEN/CLC/JTC 13 "Cybersecurity and Data Protection", the secretariat of which is held by DIN.

This document is currently submitted to the CEN Enquiry.

This document has been prepared under a standardization request addressed to CEN by the European Commission. The Standing Committee of the EFTA States subsequently approves these requests for its Member States.

Ontwerp
Draft

prEN 40000-1-2 (E)**1 Scope**

This document specifies general cybersecurity principles and general risk management activities for all products with digital elements, hereafter also referred to as 'products'. This document covers every stage of the product lifecycle to ensure and maintain an appropriate level of cybersecurity based on the risks.

This document also provides generic elements to support the development of coherent product-category-specific standards (vertical standards).

This document:

- establishes generic cybersecurity principles applicable to all stages of the product lifecycle;
- specifies requirements for risk assessment and treatment of cybersecurity risks;
- specifies requirements on activities that can be applied to ensure an appropriate level of cybersecurity at every phase of the product lifecycle;
- provides elements and considerations for product category specific standards in order to facilitate a harmonized approach.

This document does not provide vertical product category specific activities and elements.

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

prEN 40000-1-1, *Cybersecurity requirements for products with digital elements — Vocabulary*

JT013090:2026, *Cybersecurity requirements for products with digital elements – Vulnerability Handling*

3 Terms and definitions

For the purposes of this document, the terms and definitions given in Regulation (EU) 2024/2847, prEN 40000-1-1 and the following apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <http://www.iso.org/obp>
- IEC Electropedia: available at <http://www.electropedia.org/>

4 Introduction

The purpose of this document is to provide generic principles for cybersecurity and to specify activities for manufacturers covering all stages of the product lifecycle in order to ensure and maintain an appropriate level of cybersecurity based on the risks. It also supports the development of vertical standards, ensuring consistency and appropriateness.

This document is part of a set of standards that have the following structure:

- Horizontal standards for cybersecurity requirements relating to the properties of products with digital elements, including:
 - A standard for generic cybersecurity activities, providing basic concepts, definitions, principles for design and general aspects applicable to the product;

- A standard specifying generic cybersecurity requirements, presented as a catalogue of controls that may be applied to the product;
- A standard for vulnerability handling requirements for the product; and,
- A standard containing the common vocabulary used.
- Vertical standards for cybersecurity requirements relating to the properties of products with digital elements covering product category specific requirements and requirements on vulnerability handling.

[Clause 5](#) lays out the generic principles for product cybersecurity that, when applied, will lead to an appropriate level of product cybersecurity over all stages of the product lifecycle.

[Clause 6](#) provides a generic framework for managing product cybersecurity risks and lays out the requirements for appropriate cybersecurity risk management elements. It prescribes relevant elements of appropriate risk management approaches, which can be used throughout the product lifecycle and repeated when necessary.

[Clause 7](#) details requirements for generic activities during the product lifecycle, including activities related to management of cybersecurity risks. These activities are process-agnostic and can be applied across different development methodologies. They can be performed concurrently or in varying order, depending on the development approach.

[Annex A](#) details instructions for vertical standards that desire coherence with the framework established by this document.

[Annex B](#) gives an example of a Cybersecurity Supplier Agreement (CSSA) between the manufacturer and third-party providers (suppliers) of components or services.

[Annex C](#) specifies the relationship between this document and the essential requirements of CRA Annex I Part I (1) and (2) [\[1\]](#). It also identifies the normative and informative parts of the standard.

[Annex D](#) contains information to support manufacturers in developing products that are both secure and accessible to the users.

5 Cybersecurity principles

5.1 General

This clause provides an informative overview on cybersecurity principles. It established the foundation for risk management elements and activities detailed in this document to ensure an appropriate level of cybersecurity throughout all stages of the product lifecycle.

5.2 Risk-based approach to cybersecurity

5.2.1 Principle

A risk-based cybersecurity approach for products ensures that cybersecurity measures are based on identified risks and are proportionate to the identified risks, considering magnitude of loss or disruption and the likelihood of occurrence. This approach facilitates informed decision-making regarding risk treatment, ultimately aiming to reduce product cybersecurity risks across the product lifecycle through targeted and appropriate actions.

5.2.2 Guidance

A risk-based approach ensures that measures are based on identified risks, are proportionate to the level of risk, and are fit for purpose considering the intended use and reasonably foreseeable use. Risk is a combination of impact (magnitude of loss or disruption caused by an incident) and the likelihood of occurrence of said incident. The risk based approach includes implementing cybersecurity controls

prEN 40000-1-2 (E)

and other measures (e.g. constraints for the operational environment) that target either the impact or likelihood, either reducing the likelihood of a potential incident, reducing the impact of a potential incident, or both.

A risk-based approach includes:

- establishing the product context;
- risk assessment (risk identification; risk analysis, including threat modelling; and risk evaluation);
- risk treatment;
- risk monitoring and review;
- risk communication and consultation;
- risk recording.

Following the application of appropriate risk treatments, any residual risk needs to be determined to be acceptable based on risk acceptance criteria established by the manufacturer, taking into account:

- generally acknowledged state of the art;
- applicable standards and;
- the product's intended and reasonably foreseeable use.

The established context and residual risks are to be clearly communicated if required. Communication is to be traceable, accessible, and appropriate to the stakeholder's role.

5.3 Security by design

5.3.1 Principle

The principle of security by design for cybersecurity means that a product is designed, developed, and produced in a way that integrates cybersecurity measures from the concept phase throughout the entire product lifecycle. Security by design ensures that cybersecurity is treated as a fundamental aspect of the design in all its parts, and it emphasizes that it should not be regarded as an element to be added later.

5.3.2 Guidance

The security by design principle aims to create more resilient products and systems that are better equipped to withstand cyberattacks.

Key elements of the security by design principle include but are not limited to:

- **Least privilege:** Ensuring that entities have only the minimum access necessary to perform their functions, where access can be defined in different ways, e.g. levels, roles, permissions, or capabilities.
- **Attack surface minimization:** Ensuring that there are as few attack vectors and entry points as possible by which an attacker can attack. For example, this can be achieved by reducing unnecessary interfaces, or by using constant-length API parameters to reduce the likelihood of buffer overflows.
- **Defence in depth:** Implementing multiple layers of cybersecurity controls to protect against a range of threats at different layers. For example, implementing exploit mitigation techniques like non-executable pages, stack canaries, address space layout randomization, pointer authentication, and capability-based addressing.
- **Secure coding practices:** Systematically avoid or detect common causes for defects and weaknesses. For example, by using a specific programming language or using tools detecting

programming issues and deviations from best practices. Memory-safe programming languages are one type of programming language that avoids memory-safety related vulnerabilities.

- **Do not rely on security by obscurity:** Cybersecurity does not solely rely on the secrecy of design details or implementation information, but instead relies on established cybersecurity measures.
- **User-centric design:** Considering products in the context of their use, and designing products that keep users safe and secure even when user actions could lead to adverse outcomes.
- **Lifecycle management:** Implementing cybersecurity measures throughout the product lifecycle, from initial design and development to deployment, operation, end of support, until the product is permanently decommissioned and no longer used.

5.4 Secure by default

5.4.1 Principle

The principle of secure by default for cybersecurity means that the default behaviour of the product is secure for its intended purpose, reasonably foreseeable use, and intended operational environment. This involves ensuring that the product is securely configured upon installation or deployment and that available cybersecurity updates are installed without undue delay to maintain a secure by default state.

5.4.2 Guidance

The goal of secure by default is to reduce the likelihood of vulnerabilities introduced through deployment or misconfiguration by the user. This is done by minimizing the attack surface of a product, ensuring that secure configurations are the default, and informing the users about the default secure state. This may still include mechanisms to opt out, either by choice or through agreement between the manufacturer and business owner in relation to a tailor-made product. The product may also contain an option to postpone updates. In either case, proper information related to the risks needs to be provided as well as a method to reset to the secure by default state of the product.

Secure by default also entails the deactivation of unnecessary interfaces, minimising the attack surface as far as practicable considering the intended purpose and reasonably foreseeable use during setup and configuration.

The secure by design approach helps to protect users, especially those who do not have the technical knowledge to implement cybersecurity measures on their own, and it aims to reduce the likelihood of human error that can lead to cybersecurity threats. To protect users, it is important to ensure that secure configurations do not interfere with accessibility settings and vice versa.

5.5 Transparency

5.5.1 Principle

The principle of transparency refers to communicating and making available the necessary cybersecurity information to relevant stakeholders to help achieve and maintain the cybersecurity of the products.

5.5.2 Guidance

Transparency relates to sharing information, including adequate and appropriate communication towards the relevant stakeholder in an accessible and useable format. Appropriate transparency is not just about sharing information about the risks, but also considers the needs of relevant stakeholders, including accessibility requirements. This addresses aspects such as risks related to incorrect or incomplete interpretation of shared information.

Transparency includes amongst others, methods of relaying information related to:

- assets;

prEN 40000-1-2 (E)

- threats;
- risks;
- system architecture and design; and,
- exploitable vulnerabilities and incidents.

This can occur at various stages of the supply chain. Effective and transparent communication is critical for informing and involving stakeholders in risk treatment. Appropriate transparency is necessary for informed decision-making related to ensuring and maintaining cybersecurity.

6 Risk management elements

6.1 General

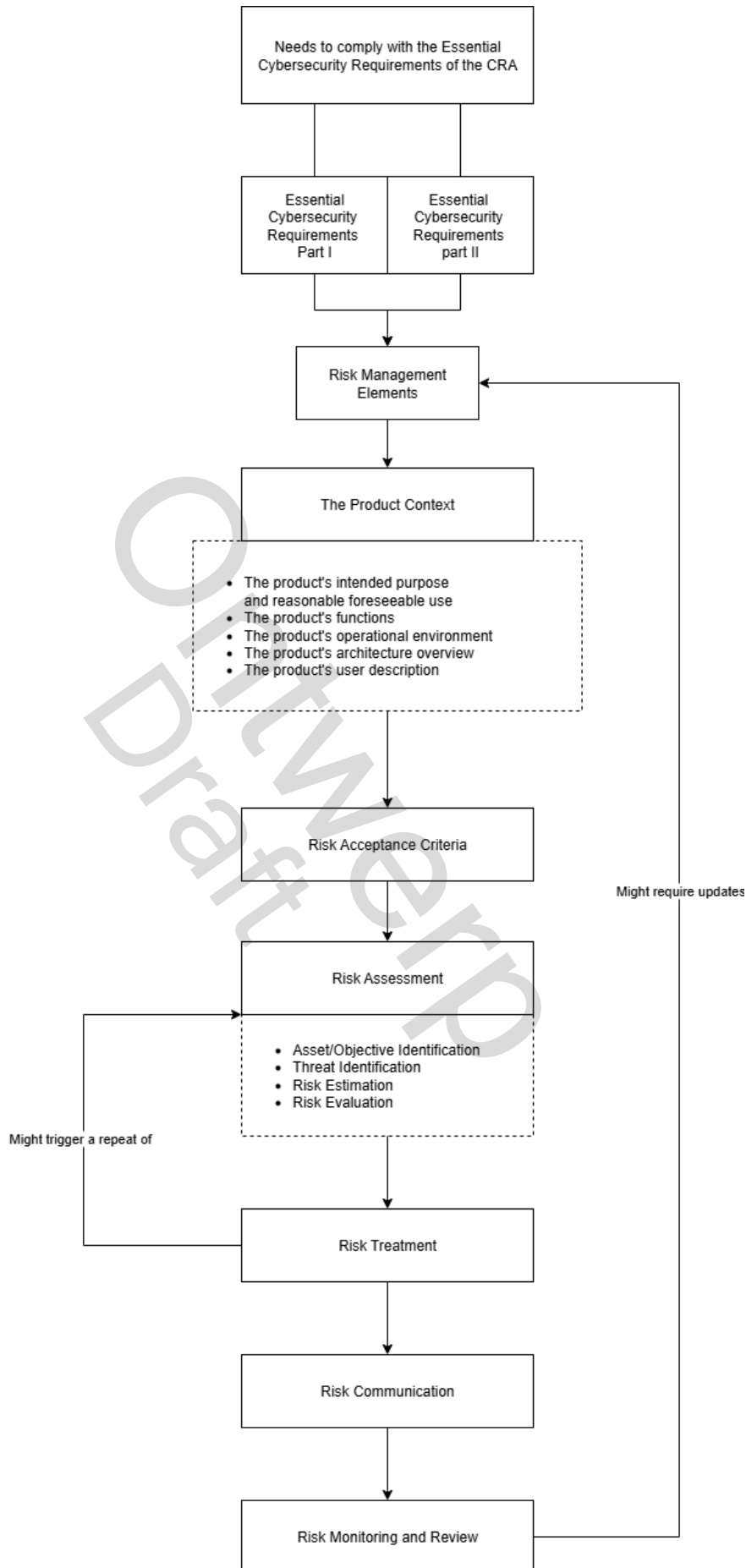
The management of risks applies to all phases of the product lifecycle, including design, development, production and maintenance to ensure an appropriate level of cybersecurity.

This clause describes generic elements to manage risks that can be applied systematically and at any point in the product lifecycle of the product. Changes in circumstances throughout the product lifecycle may trigger repetition of some elements of the risk management activities, as appropriate.

Management of risks includes the following:

- establishing the product context according to [6.2](#);
- establishing the risk acceptance criteria according to [6.3](#);
- performing an assessment of the risks according to [6.4](#);
- performing appropriate treatment of the risks according to [6.5](#);
- communicating the residual risks according to [6.6](#);
- reviewing management of the risks according to [6.7](#).

[Figure 1](#) contains a visual display of the interplay between the risk management elements.

**Figure 1 — Risk management elements overview**

prEN 40000-1-2 (E)**6.2 Product context****6.2.1 General****6.2.1.1 Context purpose**

Establishing the product context determines the starting point for the assessment and treatment of risks. This is an iterative task as changes to the product during development can cause the product context to change.

6.2.1.2 Product intended purpose and reasonable foreseeable use

The intended purpose and reasonably foreseeable use (IPRFU) of the product is essential to establish the scope and context for identifying risks.

NOTE 1 Additional information on IPRFU can be found in section 2.8 of the 'Blue Guide' on the implementation of EU product rules 2022 (2022/C 247/01) [\[2\]](#).

NOTE 2 In IPRFU, health and safety of the user and accessibility of the product by the user is considered.

EXAMPLE A smart door lock.

Intended purpose: to controls physical access to residential and office premises via a smartphone application and digital key management.

Reasonably foreseeable use:

- Users can share access credentials informally;
- Tenants can connect the lock to third-party home automation systems;
- The lock can be used in a different environment, exposing it to harsher environmental factors than was intended.

6.2.1.3 Product functions

The product's functions are those specified by the manufacturer and provided when the product is used according to its IPRFU.

NOTE The Remote Data Processing Solutions (RDPS) interfaces and dependencies are part of the product functions.

EXAMPLE 1 The functions of a product that are remotely executed or are needed to access the remote features of the product.

EXAMPLE 2 The functions of an internet gateway include forwarding network traffic from private networks to the internet and vice versa.

EXAMPLE 3 The functions of a network camera include recording optical signals and making those recordings available via a network.

EXAMPLE 4 Functions that are provided by the product when it is used according to its IPRFU can include features which ensure the defined security objectives, e.g. certain cybersecurity functions that protect the product, and the health and safety of the user.

EXAMPLE 5 The ability to configure a product is also a function in the product's IPRFU.

6.2.1.4 Product operational environment

The product's operational environment refers to the external conditions under which it is used within its IPRFU.

NOTE 1 For any RDPS, the operational environment typically contains information on connectivity, expected availability, data handled, and any constraints (including third-party platforms).

NOTE 2 The product's operational environment significantly influences the likelihood and potential impact of cybersecurity incidents caused by related vulnerabilities. It can also include existing measures that mitigate certain risks. As such, the product's operational environment plays an important role in the identification, assessment, and appropriate treatment of risks throughout the product lifecycle.

NOTE 3 A description of a product's operational environment can amongst others include:

- the networks where the product is intended and reasonably foreseen to be used, including the networks' cybersecurity relevant properties;
- the system into which the product is intended, or can reasonably be foreseen, to be integrated, together with other hardware and software components, including the relevant cybersecurity-relevant properties of this system;
- the physical surrounding of the product, where it is intended and reasonably foreseen to be operated in, including its cybersecurity relevant properties.

NOTE 4 Understanding the environment of an RDPS is essential, including where it operates, its network connections, who its users are, expected uptime, the data it manages, and any limitations.

6.2.1.5 Product architecture overview

The product architecture overview includes at least the key components of the product as well as the product interfaces and dependencies. It is a high-level overview of the components of a product and its RDPS.

NOTE 1 Where the product contains RDPS the product architecture overview describes this relation on where RDPS plays a role in delivering any stated product function. This overview also describes whether the RDPS is developed by the manufacturer or provided under the manufacturer's responsibility, and who operates it;

NOTE 2 A system can contain several components/elements. The physical components/elements of the system can be placed in different locations, interfacing with a local network and have an RDPS component.

6.2.1.6 Product user description

The product's end user, also referred to in this document as user, is any natural or legal person intended to install/operate/handle/use. This can include the use of a product as a component in another product. The description outlines the user's reasonably foreseeable level of experience, knowledge and ability to securely install/operate/maintain/decommission the product.

This includes considering if the product is to be used by vulnerable groups of users, for example those with (temporary or long term) disabilities and/or impairments. [Annex D](#) contains more information on accessible cybersecurity.

NOTE 1 The product user description typically indicates if the user is affected by RDPS dependence and any expectations placed on users or integrators.

NOTE 2 The product can be intended to be used by users with no training or expertise. In that case it is important to also account for the use by vulnerable groups of users in determining appropriate controls.

NOTE 3 The product can be intended to be used by a manufacturer as a component in their product. This entails the expectation of potential mitigation measures put in place by the user. Communication of these expectations is a critical aspect of cybersecurity for components.

6.2.2 Input

The input shall include documentation on:

- functional use cases (user stories);
- user types;
- market segments/related products (state of the art);

prEN 40000-1-2 (E)

- existing product architecture;
- existing functions.

6.2.3 Requirement

The product context shall be identified and recorded based on:

- the product's IPRFU;
- the product's functions;
- the product's operational environment of use;
- the product's architecture overview;
- the product's user descriptions.

If applicable, RDPS dependencies (e.g. a concise dependency map identifying operator, data exchanged, trust/authentication, and defined degraded modes) shall be recorded.

Where a product function relies on an RDPS, the manufacturer shall include the RDPS in the product context determination. The product including its RDPS, third-party or not, shall be treated as a single system.

It is recommended to align with the terminology used in the blue guide to describe the product user.

6.2.4 Output

The output shall include:

- the product context.
- associated evidence (due diligence) in the technical documentation.

6.2.5 Assessment criteria

Check whether the product context and the associated evidence in the technical documentation [6.2.4](#) of the product exists.

Assess whether the product context from [6.2.4](#) meets the requirements from [6.2.3](#).

The verdict PASS is assigned if:

- the description of the product context of the product exists;
- there is evidence that the product context meets the requirements.

6.3 Risk acceptance criteria and risk management methodology**6.3.1 General**

Establishing the risk acceptance criteria for products is a necessary step to determine whether risk treatment needs to be applied, whether appropriate risk treatment has been applied, and whether the residual risk is acceptable or further mitigation is required.

These criteria are established based on the product's context and are typically determined ahead of the risk assessment, although they can be adjusted during later stages of development as they are influenced over time by changes in the state of the art, the threat landscape, and other relevant factors over time. It is important to re-evaluate risk acceptance criteria when necessary.

Some circumstances justify deviating from these criteria for individual risks. Examples include situations where the user explicitly accepts certain risks, such as those introduced in tailor made

products to ensure compatibility with the customer's environment, or through other contractual agreements. Communicating the effect on the residual risk of the product is key.

Risk acceptance criteria will vary for each product context. Additionally, risks can vary depending on the phase of the product lifecycle and that of its components, such as obsolescence or depreciation.

These criteria can typically be based on a number of common elements such as:

- Regulatory factors. Legislation affecting the product can influence the degree by which a specific risk is acceptable. Examples are privacy or other safety legislation.
- Contractual agreements, stakeholder expectations or existing business practices: This incorporates a shared risk model. In this the different elements of the supply chain of a product are aware of risks and take shared responsibility to ensure the risks are mitigated. This can contain formal documents indicating shared responsibility.
- The nature of the risks such as:
 - The health and safety of the user. For some products, an exploited vulnerability of the product can lead to direct health and safety concerns for the user;
 - Discoverability and speed of materialisation of the risk. Some risks can be easily monitored and their exploitation detected by users. In other cases the user will not be aware of exploitation, or exploitation happens so rapidly that the user is incapable of intervening;
 - Attack scalability. The possibility to do attacks of scale with the product, targeting for example its RDPS. The quantity of products produced can affect the magnitude of potential loss or disruption of an exploited vulnerability in the product if multiple products are exploited simultaneously.
- The nature of the product such as:
 - Operational environment factors. The operational environment associated with the products' IPRFU can have a mitigating or magnifying effect on the product's risk. For example, if the product is used in an environment where external identity and access management is relied on, or where other systems protect the network;
 - the online hosting location or product related RDPS;
 - the number of products on the market.
- The user, the number of impacted users and their capability to mitigate risk further such as:
 - Vulnerable users. The product can be used by vulnerable users, requiring additional accessibility features or warranting a higher level of protection. An example of this is children;
 - Professional users. The product can be intended for the use by professionals or in a supervised environment, resulting in a greater ability of the user to mitigate risks themselves.

NOTE 1 When multiple Union acts address the same product a risk analysis of the product, or analysis of the intended purpose and reasonably foreseeable use, is done to determine the applicable legislation. This analysis is separate from the technical risk assessment as done in this document but the outcome can play a role in determining what risk is acceptable and what is not.

NOTE 2 The risk acceptance criteria for a component can be different from those of an end product.

NOTE 3 Selecting an appropriate threat model methodology for the product can cover most of these elements.

NOTE 4 Aligning these elements to the state of the art ensures that the risk acceptance criteria are up to date.

prEN 40000-1-2 (E)**6.3.2 Input**

The input shall include:

- the product context from [6.2.4](#);
- legal requirements;
- if available, contractual agreements, stakeholder expectations or evidence of existing business practices influencing the risk acceptance criteria.

6.3.3 Requirement

A risk assessment and treatment methodology covering how risks are defined and measure shall be defined.

This methodology shall be:

- Applied consistently on the product throughout its lifecycle;
- Justified for the product;
- Aligned with the state of the art and current values of society for the product;
- Applied to both individual risks and aggregate risks.

The risk acceptance criteria shall be defined and documented considering at least the assumptions and expectations regarding the:

- relevant regulatory factors;
- relevant contractual factors;
- nature of known risks;
- nature of the users;
- the nature of the product; and,
- state of the art and current values of society.

NOTE Product specific harmonized standards can supply risk acceptance criteria and a methodology to define and measure the risks of a product. The use of those risk acceptance criteria and that methodology would be justified and aligned with the state of the art by that standard.

6.3.4 Output

The output shall include:

- The product's cybersecurity risks acceptance criteria.
- The applied risk assessment and treatment methodology.

6.3.5 Assessment criteria

Check whether the risk acceptance criteria and the applied risk assessment and treatment methodology of the product exists.

Assess whether the risk acceptance criteria from [6.3.4](#) meets the requirements from [6.3.3](#).

Assess whether the applied risk assessment and treatment methodology from [6.3.4](#) meets the requirements from [6.3.3](#).

The verdict PASS is assigned if:

- the risk acceptance criteria of the product exists;
- the applied risk assessment and treatment methodology exists;
- there is evidence that the risk acceptance criteria of the product meets the requirements.
- there is evidence that the applied risk assessment and treatment methodology applied to the product meets the requirements.

6.4 Risk assessment

6.4.1 General

The risk assessment is based on the products' context and the risk assessment results in an evaluation of identified risks.

The assessment of risks includes:

- an identification of the assets and cybersecurity objectives according to [6.4.2](#);
- an identification of the threats according to [6.4.3](#);
- an estimation of the risks according to [6.4.4](#);
- an evaluation of the risks according to [6.4.5](#).

NOTE 1 Typically the assets are linked to more high-level objectives related to the product's context.

NOTE 2 Assets in this document refers to assets which are related to, processed by or potentially affected the product.

NOTE 3 This document does not specify methodologies for a risk analysis. As long as the risk estimation is based on the likelihood of occurrence or exploitability and the magnitude of loss or disruption after a successful attack. Thus, different approaches and models such as the fishbone model, event tree analysis, fault tree models, attack feasibility ratings or attack potential considerations can be used within the analysis of risks.

6.4.2 Asset and cybersecurity objective identification

6.4.2.1 General

Assets are typically the starting point to determine the cybersecurity objectives and help to identify threats. Assets vary widely and can include:

- data stored, processed or transmitted by the product (e.g. cryptographic keys/authentication tokens, personal data, financial data, log data);
- functions performed by the product (e.g. the capability to configure the product, the capability to communicate, the integrity of cryptographic protocols);
- software and hardware components of the product, and its interfaces;
- assets relevant for the user which are related to the use of the product;
- assets related to the protection of property, other persons, domestic animals, the environment, and public interest in general;
- the network and adjacent devices.

6.4.2.2 Input

The input shall include the product context from [6.2.4](#).

prEN 40000-1-2 (E)**6.4.2.3 Requirement**

Assets shall be identified.

The cybersecurity objectives related to the asset shall be identified.

6.4.2.4 Output

The output shall include a list of the assets and related cybersecurity objectives.

6.4.2.5 Assessment criteria

Check whether a list of the assets exists.

Check whether a list of cybersecurity objectives exists.

Assess whether assets and cybersecurity objectives from [6.4.2.4](#) is complete.

The verdict PASS is assigned if:

- the list of assets exists;
- there is evidence that the list of assets and cybersecurity objectives is complete.

6.4.3 Threat identification**6.4.3.1 General**

Threat modelling is a security design analysis technique that identifies potential security issues [EN IEC 62443-4-1:2018 \[3\]](#). Following the assets, it is now possible to determine the threats to the product. This is to be able to analyse possible risks.

Threat modelling is a structured approach for identifying threats. Threat modelling can consider the product lifecycle, how a product functions, possible threat actors and/or threat events, and identifies remaining threats to the product. Examples of threat modelling approaches are frameworks such as TVRA [ETSI TS 102 165-1 \[4\]](#), attack trees [\[5\]](#), PASTA [\[6\]](#), and STRIDE [\[7\]](#).

NOTE 1 The threat catalogue TR [T013097:2026 \[8\]](#) or comparable sector specific threat catalogues (e.g. MITRE [\[9\]](#)) can be used as input to determine common threats. Information on the product-specific threats can also be acquired from product-specific European Standards (ENs).

NOTE 2 Threat actors are entities that can intentionally or unintentionally cause harm to the product by exploiting vulnerabilities. They can include external attackers, insiders such as employees or contractors, or even unintended users who gain access to the product.

6.4.3.2 Input

The input shall include:

- the assets determined in [6.4.2](#);
- the product context from [6.2](#);
- common threats related to the product;
- relevant known exploitable vulnerabilities.

NOTE Product relevant threat can be derived from existing threat catalogues.

6.4.3.3 Requirement

Threats shall be identified and include:

- targeted asset(s);
- compromised cybersecurity objective(s) of the asset(s); and
- cause of compromise of the cybersecurity objective(s).

6.4.3.4 Output

The output shall include a list containing the threats for each asset.

6.4.3.5 Assessment criteria

Check whether a list of threats exists for each asset.

Assess whether the list of threats for each asset from [6.4.3.4](#) is sufficient.

The verdict PASS is assigned if:

- a list of the threats for each asset exists;
- there is evidence that the list of threats for each asset is sufficient.

6.4.4 Risk estimation

6.4.4.1 General

An analysis of the likelihood of occurrence and the magnitude of potential loss related to the threats is used to estimate the risks. This is needed to make the risks clearly defined and suitable for comparison with the risk acceptance criteria.

Different methods can be used to determine and express risk, based on the likelihood of occurrence and the potential magnitude of loss or disruption. This can be done in a qualitative or quantitative manner.

NOTE 1 A qualitative estimation of risks can be performed using risk matrices that map qualitative categories of the likelihood of occurrence and qualitative categories of magnitude of potential loss or disruption to qualitative risk categories.

NOTE 2 A quantitative estimation of risks can be performed using scoring systems that map qualitative categories of the likelihood of occurrence and qualitative categories of magnitude of potential loss or disruption to numerical values.

NOTE 3 Risk can, amongst others, be expressed in terms of categories of risks, and parameters for estimating likelihood of occurrence (like attack feasibility) and magnitude of loss or disruption related to risks.

NOTE 4 Considering the magnitude of potential loss or disruption through damage scenarios can enhance a risk assessment. This approach helps to better understand potential consequences and to prioritize mitigation efforts.

6.4.4.2 Input

The input shall include:

- the threats to assets from [6.4.3](#);
- the applied risk assessment methodology from [6.3](#).

6.4.4.3 Requirement

The likelihood of occurrence of each threat shall be estimated.

prEN 40000-1-2 (E)

The magnitude of potential loss or disruption related to the threat shall be estimated.

The risk, based on the likelihood of occurrence and the magnitude of potential loss or disruption, shall be estimated for each threat.

6.4.4.4 Output

The output shall include a list of all identified risks containing, for each threat, estimates of:

- likelihood of occurrence;
- magnitude of potential loss disruption;
- the risk.

6.4.4.5 Assessment criteria

Check whether the output of [6.4.4.4](#) exists.

Assess whether the output of [6.4.4.4](#) aligns the applied risk assessment methodology from [6.3](#).

The verdict PASS is assigned if:

- output of [6.4.4.4](#) exists;
- there is evidence that the output of [6.4.4.4](#) aligns the applied risk assessment methodology from [6.3](#).

6.4.5 Risk evaluation**6.4.5.1 General**

Risk evaluation identifies non-acceptable risks requiring treatment and justifies acceptable residual risks.

6.4.5.2 Input

The input shall include:

- the risk acceptance criteria from [6.3](#);
- the risks determined in [6.4.4](#);

6.4.5.3 Requirement

Each risk shall be evaluated considering:

- comparison of the risk with the risk acceptance criteria;
- justification for risk acceptance.

6.4.5.4 Output

The output shall include:

- a list of evaluated risks;
- justification for residual risk acceptance.

6.4.5.5 Assessment criteria

Check whether the output of [6.4.5.4](#) exists.

Assess whether the justification for residual risk acceptance is aligned with the risk acceptance criteria from [6.3](#).

The verdict PASS is assigned if:

- output of [6.4.5.4](#) exists;
- there is evidence that the justification for residual risk acceptance is aligned with the risk acceptance criteria from [6.3](#).

6.5 Risk treatment

6.5.1 General

6.5.1.1 Aim of risk treatment

The aim of risk treatment is to reduce or mitigate risks so that the residual risk is acceptable.

6.5.1.2 Risk avoidance

Risk avoidance involves choosing not to incorporate certain components in the product, or modifying the product's context, in order to avoid the risks related to those choices. This can help avoid some classes of vulnerabilities by, for example, using memory-safe programming languages.

Modification of the product context requires risk reassessment.

6.5.1.3 Risk mitigation

Not all risks can be avoided. For those that cannot, it is relevant to consider how to mitigate them. Risk mitigation involves implementing measures that reduce the likelihood of occurrence or magnitude of potential loss or disruption for a particular threat.

Risk mitigation requires risk reassessment, since mitigation changes existing risks and may introduce new ones.

6.5.1.4 Risk acceptance

A risk can be accepted provided it aligns with the predetermined risk acceptance criteria.

For some products, certain risks are inherent and cannot be mitigated or avoided without compromising function. This is especially relevant and prevalent for products used as components. If these risks are inherent to the product functions, their existence may be considered acceptable under the risk acceptance criteria, taking into account the product context. For such risks, it is critical to communicate their existence and the measures required to mitigate them when the product is used.

EXAMPLE A component or product lacks access controls due to the nature of its functions. In isolation this would be an issue, but when used in the intended operational environment appropriate access controls are instead provided externally. In this case, it is important to clearly communicate that the product is intended to be used in such an environment, whether physical or digital.

6.5.1.5 Risk transfer

Any risk remaining after mitigation, even if acceptable, will inherently be non-zero. This residual risk does not vanish; it is transferred to the user of the product. Communication is not needed for all residual risks, but those inherent to the intended purpose and reasonably foreseeable use are typically the risks that are to be communicated clearly and in an accessible manner.

prEN 40000-1-2 (E)**6.5.1.6 Risk treatment preference**

The different risk treatment options shall be selected based on the following order of priority, where alternatives are listed in decreasing order of preference:

- a) Risk avoidance.
- b) Risk mitigation.
- c) Risk acceptance.
- d) Risk transfer.

6.5.2 Input

The input shall include:

- the risk acceptance criteria and risk treatment methodology from [6.3](#);
- the evaluated risk from [6.4.5](#).

6.5.3 Requirement

For each risk, one or more of the following risk treatment options shall be applied in order of preference:

- risk avoidance;
- risk mitigation;
- risk acceptance;
- risk transfer.

Risk treatment options with lower priority shall not be selected if appropriate alternatives with higher priority are available.

After risk mitigation the risks shall be re-evaluated.

Risk acceptance shall only be applied when the risks are acceptable according to [6.4.5](#) and shall be documented and justified.

If the risk is acceptable because it is inherent to the product and as such mitigation or avoidance is not possible without compromising the functions of the product:

- the inherent risk shall be disclosed to the user; and,
- recommended mitigation measures for secure onboarding, integration and operation shall be communicated to the user.

Risk transfer shall only be applied when the risks are acceptable according to the evaluation of the risks and shall be documented and justified.

6.5.4 Output

The output shall include the risk treatment decision with justification per risk.

6.5.5 Assessment criteria

Check whether the output of [6.5.4](#) exists.

Assess whether the justification for the risk treatment option is aligned with the risk treatment methodology from [6.3](#).

The verdict PASS is assigned if:

- output of [6.5.4](#) exists;
- there is evidence that the justification for the risk treatment option is aligned with the risk treatment methodology from [6.3](#).

6.6 Risk communication

6.6.1 General

Risk communication refers to providing information on risks related to the product based on the product context.

It is necessary to clearly communicate all relevant risks transferred to the relevant stakeholder, as well as the actions and measures expected of the stakeholder to mitigate these risks. Where appropriately this communication considers accessibility aspects (e.g. simple language, multi-modal formats). This ensures that the stakeholder has the capability to take appropriate actions to mitigate those risks and securely use the product according to the product context.

NOTE In some cases risk will need to be communicated to more than just the user. This broader category can be referred to as stakeholders.

6.6.2 Input

The input shall include:

- the threats from [6.4.3.4](#);
- the risks from [6.4.4.4](#);
- the risk treatment decisions from [6.5.4](#).

6.6.3 Requirement

The communication of relevant risks to affected stakeholders shall be carried out using a method and terminology that meets the communication needs of each stakeholder.

Where appropriate, the communication with the affected stakeholder shall consider accessibility aspects (e.g. simple language, multi-modal formats) for each stakeholder.

The communication of the product's risks to affected stakeholders shall include:

- disclosure of residual risks, e.g. a description of circumstances related to the context that can lead to significant cybersecurity risks;
- recommended mitigation measures for the stakeholder, e.g. the environment for onboarding, integration and operation;
- relevant assumptions about the product context for onboarding, integration and operation;
- expectations set on end users and downstream integrators.

NOTE 1 Where relevant to the CRA [\[1\]](#) this information can be added to the information and instructions to the user.

NOTE 2 Communication needs depend on the stakeholder. End users can have impairments that prevent them from accessing this information in written format, or prevents access to the information if it is only available on a website. When dealing with other manufacturers it can be enough to have the information written in a language they are able to understand.

prEN 40000-1-2 (E)**6.6.4 Output**

The output shall include:

- documentation containing the risk treatment information for the stakeholder;
- documentation containing what is expected from the user, added to the information and instructions to the user.

6.6.5 Assessment criteria

Check whether the output of [6.6.4](#) exists.

Assess whether the documentation containing the risk treatment information for the stakeholder contains sufficient information to mitigate the risk.

Assess whether the documentation containing what is expected from the user contains sufficient information to mitigate the risk.

The verdict PASS is assigned if:

- output of [6.6.4](#) exists;
- there is evidence that the documentation containing the risk treatment information for the stakeholder contains sufficient information to mitigate the risk;
- there is evidence that the documentation containing what is expected from the user contains sufficient information to mitigate the risk.

6.7 Risk monitoring and review**6.7.1 General**

It is important to review and, if necessary, update the elements of risk management to address potential changes in the threat landscape and state of the art. This review can be triggered by the observation that the threat landscape has changed or can be done on a regular basis if required.

Review of the risk assessment helps to create awareness of potential cybersecurity issues.

NOTE Updating relevant parts of the risk management can include adding or modifying product controls.

6.7.2 Input

The input shall include:

- the product context from [6.2](#).
- the risks acceptance criteria from [6.3](#).
- the evaluated risks from [6.4.5](#).
- the risk treatment decision from [6.5](#).
- risk treatment information for stakeholders from [6.6](#).

6.7.3 Requirement

The regularity with which to review the risk management shall be determined based on risk and justified.

The reviewing of the risk management shall be performed:

- regularly as appropriate to the product's context and implementation;

- when the product's cybersecurity risk exposure changes (including changes to the threat landscape and review of the threat model as required);
- when cybersecurity issues occur (e.g. severe incidents, actively exploited vulnerabilities, obsolescence of components) that have an impact on the cybersecurity of the product.

The review of the outcome of the risk management shall cover at least the relevant parts of [Clause 6](#).

NOTE This document cannot specify the regularity with which to monitor or review. Context specific information is needed to specify this information.

6.7.4 Output

The output shall include:

- at what regularity the reviewing of the risk management shall be performed;
- justification for the regularity with which the reviewing of the risk management shall be performed.

And if the review of the risk management has been triggered it shall contain updates of the relevant documentation of [Clause 6](#).

6.7.5 Assessment criteria

Check whether the regularity with which the reviewing of the risk management shall be performed of [6.7.4](#) has been determined.

If the review of the risk management has been triggered, check whether updates of the relevant documentation of [Clause 6](#) exist.

Assess whether the justification for the regularity with which the reviewing of the risk management shall be performed is reasonable based on the risk.

Assess whether the updates of the relevant documentation of [Clause 6](#) cover the changes needed due to the trigger of the review.

The verdict PASS is assigned if:

- the regularity with which the reviewing of the risk management shall be performed of [6.7.4](#) has been determined.
- there is evidence that the assessment and justification to determine on what regularity the reviewing of the risk management shall be performed is reasonable for the product context and implementation.
- when the review has been triggered, that there is evidence that the updates of the relevant documentation of [Clause 6](#) cover the changed needed due to the trigger of the review.

7 Cybersecurity activities

7.1 General

Product cybersecurity activities are intended to be process agnostic. There are logical connections between activities: some are prerequisites for others but, with certain development methodologies (including agile approaches), the activities in this clause can be executed concurrently or in any order. Furthermore, many activities can be revisited at relevant points or regular intervals as a change in one can imply changes in several others. In that case, it is necessary to document the dependencies between process activities.

prEN 40000-1-2 (E)**7.2 Product cybersecurity planning****7.2.1 General**

Cybersecurity planning involves describing the cybersecurity activities for a product throughout its lifecycle. Relevant activities are found in [Clause 6](#) and [Clause 7](#). Many activities are interrelated. Changes in one activity can affect others.

NOTE This type of planning can include considerations on the roles and responsibilities, as well as ensuring that that personnel are adequately trained, as appropriate for the manufacturer.

7.2.2 Input

The input shall include the output from the activities described in [Clause 6](#) and [7.3](#) through [7.11](#).

7.2.3 Requirement

The planning of cybersecurity shall be documented, containing:

- activities to be executed to support and maintain cybersecurity of the product throughout its lifecycle;
- risk acceptance criteria and rationale [6.3.4](#);
- methodologies used (e.g. threat modelling, risk assessment, vulnerability assessment) [6.3.4](#);
- support period and decommissioning plan [7.10](#);
- recurring testing and review schedule (effective and regular testing and review);
- update, upgrade and component obsolescence planning;
- vulnerability response planning (e.g. typical timescales for vulnerability handling).

The documentation shall be maintained and reviewed regularly.

NOTE Review and update intervals are difficult to guarantee, as they can depend on external parties and factors outside the manufacturer's control.

7.2.4 Output

Documentation containing the requirements in [7.2.3](#).

7.2.5 Assessment criteria

Check whether the cybersecurity planning documentation from [7.2.4](#) exists.

Assess whether the documentation from [7.2.4](#) meets the requirements of [7.2.3](#).

The verdict PASS is assigned if:

- the cybersecurity planning documentation exists;
- there is evidence that the documentation meets the requirements.

7.3 Product cybersecurity requirements**7.3.1 General**

The product cybersecurity requirements:

- are managed throughout the product lifecycle, in line with the management of cybersecurity risks, in particular the assessment and treatment of product cybersecurity risks; and

- are based on the needs and expectations of stakeholders relevant to the product, as well as regulatory product requirements such as those of the CRA [1].

In addition, the identification and formulation of product cybersecurity requirements typically consider:

- the traceability, validity, understandability and verifiability of product cybersecurity technical specifications;
- the cybersecurity properties of the product's environment during development and production.

These requirements can then be fulfilled through the implementation of specific cybersecurity controls, typically selected from different catalogues.

NOTE 1 In line with ISO/IEC terminology, "requirements" in this document can express obligations, permissions, or prohibitions. They define what is expected. "Controls" (sometimes also referred to as safeguards) are the measures implemented to fulfil those requirements.

NOTE 2 Examples of catalogues of cybersecurity controls:

- [IT013091:2026 \[10\]](#) (These controls are related to the essential requirements of the CRA [1]);
- [ETSI EN 303 645 \[11\]](#);
- [EN IEC 62443-4-2 \[12\]](#);
- [EN ISO/IEC 15408-2:2020 \[13\]](#);
- [EN ISO/IEC 27002:2022 \[14\]](#);
- Guideline "State of the art " in IT security Technical and organisational measures 2025 [15];
- NIST SP 800-53 Rev. 5 Security and Privacy Controls for Information Systems and Organizations [16].

7.3.2 Input

Input shall include:

- the product context from [6.2.4](#);
- the risk acceptance criteria and the applied risk assessment and treatment methodology from [6.3.4](#);
- assessment of product cybersecurity risks from [6.4.4.4](#);
- treatment of product cybersecurity risks (in particular risk reduction through the implementation of product controls) from [6.5.4](#);
- applicable regulatory requirements;
- expectations of relevant stakeholders;
- applicable state of the art.

7.3.3 Requirement

The product cybersecurity requirements shall be established based on the inputs.

Established cybersecurity requirements shall:

- be documented with respect to their applicability and effectiveness to achieve the cybersecurity objectives for the assets;
- have their technical specifications documented;
- have applicable controls selected to fulfil them.

prEN 40000-1-2 (E)

The product cybersecurity requirements shall be reviewed and when necessary updated when there are changes in any of the listed inputs.

7.3.4 Output

The output shall include documented product cybersecurity requirements.

7.3.5 Assessment criteria

Check whether documentation specifying the product cybersecurity requirements from [7.3.4](#) exists.

Assess whether the documentation of the product cybersecurity requirements from [7.3.4](#) meets the requirements from [7.3.3](#).

The verdict PASS is assigned if:

- documentation specifying the product cybersecurity requirements exists;
- there is evidence that the documentation meets the requirements specified in [7.3.3](#).

7.4 Cybersecurity architecture and design**7.4.1 General**

The secure architecture and the functional design of the product are based on the cybersecurity requirements as defined in [7.3](#) and the product context as defined in [6.2](#).

Consider the following for the product cybersecurity architecture and design:

- introduce trust boundaries between components and subsystems including RDPS, to ensure clear separation of privileges and responsibilities, as well as containment;
- secure interface design, with particular attention to authentication, input validation, and minimization of the exposed attack surface.

7.4.2 Input

The input shall include:

- product context definition from [6.2.4](#);
- list of assets and cybersecurity objectives from [6.4.2.4](#);
- cybersecurity requirements from [7.3.4](#).

7.4.3 Requirement

The cybersecurity architecture and design of the product shall be established.

The cybersecurity architecture and design for the product shall consider appropriate elements from:

- the security by design principle from [5.3](#); and,
- the secure by default principle from [5.4](#).

The cybersecurity architecture and design shall ensure that third-party component integration is performed with due diligence, aligned with [7.11](#) and [7.5](#).

In case the product contains third-party components or RDPS as identified in the product context, due diligence shall be applied to all components, whether third-party or not, and to their integration.

7.4.4 Output

The output shall include the documented cybersecurity architecture and design for the product.

7.4.5 Assessment criteria

Check whether documentation specifying the secure product architecture and design from [7.4.4](#) exists.

Assess whether the documentation of the secure product architecture and design from [7.4.4](#) meets the requirements from [7.4.3](#).

The verdict PASS is assigned if:

- the secure product architecture and design documentation exists;
- there is adequate evidence that the description of the secure product architecture and design meets the requirements on the product's cybersecurity architecture.
- there is adequate evidence that the cybersecurity architecture and design for the product is consistent with the cybersecurity requirements identified in [7.4.3](#).

7.5 Secure implementation

7.5.1 General

Secure implementation activities ensure the development of secure product that can be tested against the previously defined cybersecurity requirements from [7.3](#). Special considerations for secure implementation include configuring the cybersecurity properties of components to be integrated into the product.

Activities of secure implementation can include, but are not limited to:

- Maintenance of the Software Bill of Materials (SBOM). The SBOM lists the components used in the software, covering at least the top-level dependencies and relevant parts that qualify it for vulnerability monitoring. That entails all relevant components of an asset or a group of assets.
- Managing dependencies and third-party libraries by selecting secure libraries and keeping them up to date. Follow the due diligence in [7.11](#) when selecting secure libraries;
- Secure code development. Manufacturers often use a set of coding standards and guidelines to write secure code. These standards help maintain code quality and consistency, and in avoiding common programming errors that could lead to cybersecurity vulnerabilities. Different rules apply for different programming languages. Ensure that the rules are appropriate for each programming language used. Secure coding practices include using secure functions, prohibiting hard-coded credentials, and implementing proper error handling;
- Secure coding and strategies to ensure memory safety, including practices to avoid buffer overflows, memory leaks, and other memory-related vulnerabilities. This may involve using safe programming languages, employing memory management techniques, and utilizing tools for detecting common defects;
- Development of the technical documentation as well as information and instructions for users and stakeholders (CRA Annex VII and II[1]).

The secure implementation can result in deviations from the design documentation. Such deviations can lead to more or less secure behaviour of the product and could impact the secure architecture, the functional design, and the cybersecurity risk management activities.

prEN 40000-1-2 (E)

A secure implementation typically relies on a securely maintained development environment that, amongst other things:

- prevents unauthorized access to components and source materials;
- includes software tools for managing, developing and implementing the software and other product-related artefacts;
- manages cryptographic keys and certificates using technology appropriate to their sensitivity.

7.5.2 Input

The input shall include:

- cybersecurity requirements from [7.3.4](#);
- secure product architecture and design from [7.4.4](#);
- due diligence of third-party components to be implemented and integrated into the product from [7.11](#).

7.5.3 Requirement

The product shall be developed and maintained in a secure manner, including through the use of a secure development environment.

Secure implementation shall ensure that all selected cybersecurity controls are correctly implemented for the product. Secure implementation shall, where appropriate to the design and scope of the product, include the following activities:

- Preparation and maintenance of an SBOM appropriate for the product;
- Confirmation of the vulnerability status of integrated components and their integration, to ensure that cybersecurity risks are addressed in the implemented design.
- Use of appropriate technology for the management of cryptographic keys and certificates;
- Preparation of the technical to and information and instructions to the User, made available in an accessible manner and in a language easily understood by the user.

NOTE The cybersecurity of a component and its integration can change at any point throughout the development cycle and therefore, it is important to verify component cybersecurity at multiple phases.

7.5.4 Output

Secure implementation shall include:

- hardware or software, including remote data processing software;
- updated cybersecurity requirements, including threat models where appropriate;
- an SBOM;
- technical documentation and information and instructions to the user;
- evidence of the outcomes of the activities undertaken, as specified in the requirement.

7.5.5 Assessment criteria

Check whether the output of the secure implementation from [7.5.4](#) exists.

Assess whether the output from [7.5.4](#) meets the requirements from [7.5.3](#).

The verdict PASS is assigned if:

- the output of the secure implementation exists;
- there is adequate evidence that the output of the secure implementation meets the requirements.

7.6 Cybersecurity verification and validation

7.6.1 General

The goal of cybersecurity verification and validation (V&V) is to ensure that the concept, design and implementation of a product satisfy all respective cybersecurity requirements, and that the product is sufficiently cybersecure considering its context.

V&V is crucial for detecting potential cybersecurity defects (such as coding mistakes, configuration errors, or design flaws) that could be exploited by malicious actors. Through V&V, the manufacturer identifies and mitigates or eliminates these vulnerabilities before the product is deployed or released, thereby reducing the risk of successful cyberattacks.

Cybersecurity V&V focuses on ensuring:

- that the product includes all intended cybersecurity functions and cybersecurity controls, as identified in the cybersecurity requirements from [7.3.4](#);
- that the implemented cybersecurity controls are effective.

Cybersecurity V&V is a recurring activity integrated throughout the entire lifecycle, not only at the final stages. V&V often uncovers implementation issues that can trigger design changes; therefore, these activities are normally repeated until all cybersecurity issues are addressed. V&V is also carried out whenever the product changes, such as during maintenance or after resolution of newly uncovered vulnerabilities.

For cybersecurity V&V, the testing environment is normally separated from the product's operational environment. It is a recommended practice to ensure that the testing environment is secure. Where possible, cybersecurity V&V is preferred to be carried out in an isolated environment.

Cybersecurity V&V often includes but are not limited to the following approaches:

- Cybersecurity analysis: a systematic evaluation process in which cybersecurity-related artefacts, such as design, specification, user and technical documentation, and code are examined. This can include inspections, walkthroughs, V&V reviews etc., undertaken to determine the suitability, adequacy, and effectiveness of the subject matter in achieving established cybersecurity objectives.
- Unit testing: focuses on verifying that small, functional units of software behave securely and as intended. It is considered a best practice in software development to implement software as testable units and to write corresponding unit tests for each. Unit tests support regression testing, provide living documentation of expected behaviour, facilitate integration, and encourage good design.
- Integration testing: Performed to verify the interaction between different components and identify any cybersecurity gaps that can arise;
- System testing: Evaluates the overall cybersecurity of the product and its cybersecurity features, including its resilience to various attack scenarios;
- Fuzz testing (Fuzzing): Involves subjecting the product or its components to a wide range of unexpected, random, or invalid inputs in order to detect vulnerabilities and software defects, such as crashes, memory leaks, or unexpected behaviour.

prEN 40000-1-2 (E)

- Stress testing: Involves stressing the product during runtime to evaluate how it handles resource usage and demand. These tests often reveal issues such as denial-of-service vulnerabilities, memory leaks, or inefficient resource handling.
- Penetration testing: Involves simulating real-world attacks to identify vulnerabilities and assess the product's ability to withstand them;
- Vulnerability monitoring: involves identifying and assessing vulnerabilities in the software and hardware components used in the product. It can involve scanning the product with specialized tools to detect cybersecurity defects by querying vulnerability databases, or identification of typical indicators for specific defect classes.

NOTE Cybersecurity analysis can be done manually or automatically.

7.6.2 Input

The input shall include:

- hardware or software, including RDPS, to enable cybersecurity testing of the product;
- draft technical documentation and information and instructions to the user;
- the cybersecurity requirements from [7.3.4](#);
- the applied threat model from [6.3.4](#).

7.6.3 Requirement

Cybersecurity verification and validation (V&V) shall be performed to ensure that the implemented cybersecurity functions and controls fulfil the intended cybersecurity requirements of the product, and the overall product is secure within its context.

Cybersecurity V&V shall, where appropriate to the product's design, scope and risk, include the following activities:

- Reviewing the product implementation, including design and implementation artefacts for software or/and hardware components, through peer review or automated tooling;
- Validating that the product implementation is consistent with the cybersecurity requirements and the threat model;
- Verifying that threats and known vulnerabilities of the product, third-party components and their integration have been subject to appropriate risk treatment in accordance with the cybersecurity requirements;
- Validating that the implemented design appropriately handles errors, including input data validation;
- Verifying and validating the product, including external interfaces and protocols, to identify vulnerabilities. Testing may be executed manually or using automated testing tools, and may include methods such as load testing and fuzz testing;
- Conducting penetration testing to discover and exploit cybersecurity vulnerabilities in the product;
- Verifying the cybersecurity technical documentation and information and instructions to the user to ensure they provide accurate and sufficient guidance;
- Reviewing that the implementation artefacts meet the requirements defined by the manufacturer's secure implementation rules, such as secure coding rules.

- Performing recurring V&V activities to ensure that products are regularly tested and reviewed for vulnerabilities within the product's lifecycle, with appropriate scheduling of risk analysis updates, including the threat model.

7.6.4 Output

The output shall include:

- documentation of the cybersecurity V&V results (e.g. test reports);
- evidence that the cybersecurity controls implemented fulfil the intended cybersecurity objectives and are aligned with the product's cybersecurity requirements.

7.6.5 Assessment criteria

Check whether the output of the cybersecurity V&V from [7.6.4](#) exists.

Assess whether the output of the cybersecurity V&V from [7.6.4](#) meets the requirements from [7.3.3](#).

The verdict PASS is assigned if:

- the output of the cybersecurity V&V exists;
- there is adequate evidence that the output of the cybersecurity V&V meets the requirements.

7.7 Secure production and distribution

7.7.1 General

Secure Production & Distribution activities ensure that the cybersecurity risks to the product are managed throughout the manufacturing and distribution process. These activities address the cybersecurity risks associated with producing and distributing the product.

For software products delivered digitally, this includes ensuring that the integrity and authenticity of the software is protected during delivery to the user.

For hardware products, or software products placed on the market with a hardware component, such as a gaming system disk or memory card, measures are needed to ensure that the components and data are protected from manipulation from the time of release from the development team, during the entire manufacturing process, and until the product is delivered to the user.

A secure production control plan can support secure production activities. The secure production control plan often includes, but is not limited to:

- sequence of cybersecurity-relevant steps to produce the product;
- production controls to prevent unauthorized alteration of the product during production, including:
 - physical production controls that prevent physical access to production servers holding software;
 - logical production controls that apply cryptographic techniques, cybersecurity configuration settings, and/or access controls.
- methods to confirm that the product is produced according to the cybersecurity specification.

NOTE A secure production control plan can be included as part of an overall production plan.

prEN 40000-1-2 (E)**7.7.2 Digital production****7.7.2.1 General**

Digital production relates to activities for the production of software products and software updates, including compiling, building, packaging, and preparing software artefacts for distribution through digital channels.

NOTE Digital production also applies to software updates for hardware products. For certain product categories, such updates are commonly referred to as firmware updates.

Activities in the secure digital production process ensure that digital products are protected from manipulation by external actors during digital distribution (for instance, via an online hosting platform such as an app store).

Follow the measures defined in [7.6](#) to ensure that information supporting the product is complete, accurate and written in an appropriate language before distribution.

7.7.2.2 Input

The input shall include:

- digital files including:
 - artefacts used for distribution of the validated and verified software product, such as software packages, binaries, other digital data;
 - supplementary digital documentation, including technical information and instructions to the user;
- a due-diligence cybersecurity assessment of the digital distribution channel (e.g. online hosting platform or manufacturer's download site).

7.7.2.3 Requirement

Secure digital production shall ensure that digital products, such as software images and other distribution artefacts, are protected from manipulation during distribution, considering both when artefacts are in transit and when artefacts are stored.

The secure digital production activities shall, where appropriate to the risk, the design and scope of the product, include the following measures to limit attack surface and to reduce the likelihood of cybersecurity incidents:

- appropriate authentication for accessing protected areas of the online hosting location;
- protection of the integrity of digital files during distribution, considering both transit and storage;
- Mechanisms that ensure the authenticity of distributed artefacts;
- verification and Validation of the above requirements.

Where applicable, information relevant to the stakeholder shall be protected during distribution. This includes the communication channels of the technical information and instructions for the stakeholder.

7.7.2.4 Output

The output shall include:

- software product artefacts prepared for distribution through a digital channel;
- securely hosted digital product, including remote data processing solutions;

- an established secure distribution channel for technical information and instructions to the user;
- evidence that the requirements are met in accordance with [7.7.2.3](#).

7.7.2.5 Assessment criteria

Check whether the output of the secure digital production from [7.7.2.4](#) exists.

Assess whether the output of the secure digital production from [7.7.2.4](#) meets the requirements from [7.7.2.3](#).

The verdict PASS is assigned if:

- the output of the secure digital production exists;
- there is evidence that the output of the secure digital production meets the requirements.

7.7.3 Manufacturing

7.7.3.1 General

Manufacturing relates to the production of tangible products, such as hardware products, or software products placed on the market with a hardware component or using other physical media (such as a memory card or a compact disc).

Activities in the secure physical production process ensure that the production process is protected from manipulation by external actors.

It is recommended to consider the following aspects for a Secure production and production environment:

- change management activities to ensure process changes are verified for cybersecurity impact;
- protection of systems and processes used in manufacturing the product;
- protection of any data supporting the production activities;
- tamper-resistance or tamper-evidence for packaged products.

7.7.3.2 Input

The input shall include:

- authentic digital data for production (e.g. software package, binary, configuration files);
- verified and validated work instructions for the manufacturing process.

7.7.3.3 Requirement

Secure manufacturing shall mitigate risks, arising from any product with a hardware component being manipulated or altered by unauthorized actors during the manufacturing process.

Secure physical production activities shall, where applicable and appropriate to the risk, the design and scope of the product, include the following measures to limit the attack surface and to reduce the likelihood of cybersecurity incidents:

- based on risk, protection of the confidentiality, authenticity and integrity of work instructions for operators involved in production activities;
- verification of expected product components and their associated firmware, software or other data as part of production activities;

prEN 40000-1-2 (E)

- based on risk and defined security controls, protection for confidentiality, authenticity and integrity of installed software, data or configurations (e.g. cybersecurity settings, keys, identifiers, advisories) within or transmitted to or from the manufacturing environment, including ensuring that programming and testing features on an embedded device are restricted from unauthorized use;
- protection and authentication management of cybersecurity features used in the product (e.g. PKI management).

7.7.3.4 Output

The output shall include evidence of the activities undertaken as per [7.7.3.3](#).

7.7.3.5 Assessment criteria

Check whether the output of the secure physical production from [7.7.3.4](#) exists.

Assess whether the output of the secure physical production from [7.7.3.4](#) meets the requirements from [7.7.3.3](#).

The verdict PASS is assigned if:

- the output of the secure physical production exists;
- there is evidence that the output of the secure physical production meets the requirements.

7.8 Cybersecurity issue management**7.8.1 General**

Cybersecurity issue management is the activity ensuring that cybersecurity issues can be identified, handled and resolved for the product. It is a key aspect of the maintenance of a product. Cybersecurity issues here are considered to be either vulnerabilities or incidents affecting the product including its RDPS.

Documentation requirements, periodic testing and review, disclosure requirement and other obligations are further explained in [\[T013090:2026 \[17\]\]](#).

7.8.2 Input

The input shall include internal and external sources for collecting information about product related cybersecurity issues, including reports provided through third-party vulnerability disclosure.

7.8.3 Requirement

Potential cybersecurity issues shall be identified.

Potential cybersecurity issues shall be assessed.

Cybersecurity issues shall be treated appropriately and without undue delay.

If applicable, information about cybersecurity issues shall be disclosed, including published workarounds or advisories.

7.8.4 Output

The output shall include:

- a log of the cybersecurity issues identified for the product, including the status, timeline, analysis and applied handling;
- user instructions including, the means for delivering software updates to the user in an accessible formats and language that is easily understood by the user.

7.8.5 Assessment criteria

Check whether the output of the cybersecurity issue management from [7.8.4](#) exists.

Assess whether the output of the cybersecurity issue management from [7.8.4](#) meets the requirements from [7.8.3](#).

The verdict PASS is assigned if:

- the output of the cybersecurity issue management exists;
- there is evidence that the output of the cybersecurity issue management meets the requirements.

7.9 Product monitoring

7.9.1 General

Monitoring the threat landscape of a product is essential for responding to changes and for detecting new vulnerabilities, which in turn supports the prevention of incidents.

The aim of product monitoring is to identify cybersecurity-related issues during the product lifecycle. It typically includes identifying, receiving, and processing, where applicable, cybersecurity-related issues from internal and external sources throughout the different phases of the product lifecycle .

NOTE 1 If the product has the ability, cybersecurity-related information can be collected by recording relevant internal activity, including, but not limited to, access to or modification of data, services or functions, with an opt-out mechanism for the user.

NOTE 2 Monitoring can help identify changes in the product's threat landscape.

NOTE 3 Monitoring can include monitoring of vulnerability databases, and other sources of vulnerability reports, either manually or through automated means.

NOTE 4 Additional insights can be gathered from cybersecurity laboratories, from similar products on the market or from market surveillance authorities.

7.9.2 Input

The input shall include:

- documentation relevant to communication from [6.6.4](#);
- risk related documentation from [6.4](#);
- product cybersecurity architecture and design from [7.4.4](#);
- secure implementation documentation from [7.5.4](#);
- verification and validation documentation from [7.6.4](#).

7.9.3 Requirement

Product monitoring shall identify cybersecurity related issues during the product lifecycle;

prEN 40000-1-2 (E)

In case a new vulnerability is discovered, the vulnerability shall be documented and the risk analysis from [Clause 6](#) shall be reviewed and if needed updated.

Discovered vulnerabilities shall be treated as per JT013090:2026.

7.9.4 Output

The output shall include evidence that cybersecurity related issues identified during the product lifecycle of the product are monitored.

7.9.5 Assessment criteria

Check whether the output of the product monitoring from [7.9.4](#) exists.

Assess whether the output of the product monitoring from [7.9.4](#) meets the requirements from [7.9.3](#).

The verdict PASS is assigned if:

- the output of the product monitoring exists;
- there is evidence that the output of the product monitoring meets the requirements.

7.10 Planning for secure decommissioning**7.10.1 General**

Planning for secure decommissioning is the activity preparing for securely retiring a product, including its RDPS, ensuring the user's assets are not compromised when the product changes user or when it is disposed of at the end of its operational life. Typically, this relates to the secure deletion of the user's assets, such as user related data and settings and cryptographic keys, this aspect of decommissioning is covered by [JT013091:2026 \[10\]](#).

Once a product and its included RDPS reach their end of the support period there can be other obligations to inform the users about the end of the support period and the impact on the continued use of the product. Accounting for this aspect of decommissioning and any activities the manufacturer has remaining at and beyond the end of the support period is part of the planning for secure decommissioning.

7.10.2 Input

The input shall include:

- the product context from [6.2.4](#);
- the product assets from [6.4.2.4](#);
- product architecture and design from [7.4.4](#).

7.10.3 Requirement

The manufacturer shall document planning for secure decommissioning of the product and related services, containing at least:

- cybersecurity considerations to be taken into account for decommissioning;
- the confidential assets, such as user related data and settings and cryptographic keys, that need to be securely deleted and where those are logically located;
- where a third-party or the manufacturer is operating parts of the product, appropriate actions to ensure the product can be securely decommissioned;

- relevant user information and instructions to the user as well as the method by which the user is informed about the decommissioning of product related services;
- obligations that extend beyond the end-of-support.

Relevant user information and instructions to the user shall contain at least:

- how to remove or export the user data;
- how to remove cybersecurity assets, and configuration data stored within the product;
- if applicable, how to remove the product from its intended operational environment;
- if applicable, how to securely dispose of the product to prevent potential disclosure of data contained in the product that could not be removed as described above;
- for any data removed automatically, information on what will be deleted and when.

7.10.4 Output

The output shall include documentation containing the requirements from [7.10.3](#).

7.10.5 Assessment criteria

Check whether the output of the decommissioning from [7.10.4](#) exists.

Assess whether the output of the decommissioning from [7.10.4](#) meets the requirements from [7.10.3](#).

The verdict PASS is assigned if:

- the output of the decommissioning exists;
- there is evidence that the output of the decommissioning meets the requirements.

7.11 Third-party component cybersecurity management

7.11.1 General

Third-party components with digital elements (shorten to third-party components afterwards) can introduce cybersecurity risks to products.

Cybersecurity risks of third-party components are relevant because vulnerabilities in these components can compromise the cybersecurity and integrity of the product. It is important to take due diligence when selecting and incorporating third-party components.

Third-party component cybersecurity management specifies the requirements and activities to ensure that cybersecurity risks relevant to third-party components integrated into the product are handled with due diligence and other relevant activities. This contains such tasks as:

- assessing that the intended purpose and reasonably foreseeable use of the third-party component aligns with the use/integration within the product;
- evaluating that the third-party component is compliant with applicable legal and contractual requirements and the cybersecurity requirements in particular for the product. This can be done by, amongst others, checking for:
 - a CE marking, if available;
 - verification that there are no vulnerabilities registered in the European vulnerability database established pursuant to Article 12(2) of Directive (EU) 2022/2555 [\[18\]](#) or other publicly available vulnerability databases;

prEN 40000-1-2 (E)

- indicators of cybersecurity by design;
- availability of regular cybersecurity patches;
- vulnerability disclosure and handling;
- a risk assessment;
- checking if additional cybersecurity testing is required.
- considering the support period of components when selecting them for integrating these into the product. This anticipates the risks arising from deprecated third-party component and obsolete technologies;
- assessing the risk of the third-party component and its integration in the risk assessment of [6.4](#);
- securely incorporating the third-party component according to [7.5](#);
- monitoring for vulnerabilities in the third-party component over the product lifecycle according to [7.9](#);
- communicate newly found vulnerabilities in the third-party component as well as sharing potential solutions if available.

In order to improve overall cybersecurity it is relevant to communicate any newly discovered vulnerabilities to the responsible third-party. This third-party can be a supplier, service provider, an open-source steward, or any party that is responsible for the cybersecurity of the third-party component introduced in the product.

Information sharing about potential vulnerabilities can be agreed through agreements between relevant stakeholders, for example through a coordinated vulnerability handling process.

To support a culture of transparency and collective cybersecurity improvement, manufacturers may share with the third-party any developed fixes for vulnerabilities found in the supplier's component.

NOTE To ensure that all necessary and distributed cybersecurity activities related to third-party components are clearly assigned and agreed, manufacturers are advised to align responsibilities with their suppliers and document it before bringing a product to the market. This can be done for example using the template provided in [Annex B](#). This supports implementation of the requirements outlined in the requirement subclause [7.11.3](#) and promotes consistent collaboration across the supply chain.

7.11.2 Input

The input shall include documentation of third-party components used in the product.

7.11.3 Requirement

Due diligence shall be applied to the selection of the third-party components.

The selection of the third-party components shall be justified and documented.

Third-party components and their integration shall be included in the risk assessment and treatment activities contained in [Clause 6](#);

Third-party components shall be securely implemented and integrated as aligned with [7.5](#).

Third-party software components shall be added to the SBOM to manage dependencies in accordance with [7.5](#);

Third-party components and their integration shall be validated and verified as aligned with [7.6](#);

Third-party components shall be monitored over their lifecycle to identifying relevant vulnerabilities for the product according to [7.9](#).

Discovered vulnerabilities in third-party components shall be documented, disclosed to the relevant third-party entities and remediated according to the vulnerability disclosure and handling procedures.

7.11.4 Output

The output shall include:

- documented evidence that due diligence has been applied for the selection of third-party components and their integration;
- documented evidence of the inclusion of third-party components to the performance of relevant activities mentioned in [7.11.3](#).

7.11.5 Assessment criteria

Check whether the output from [7.11.4](#) exists.

Assess whether the output from [7.11.4](#) meets the requirements from [7.11.3](#).

The verdict PASS is assigned if:

- the output exists;
- there is evidence of due diligence that meets the requirements for third-party components.

Annex A (informative)

Coherence with vertical standards

A.1 Coherence elements

Manufacturers can seek out product category-specific “vertical” standards coherent with this document in order to supplement its requirements and to demonstrate conformity. If no vertical standards are available, a manufacturer can carry out these actions on their own. To seek this coherence, the following actions can be taken:

- aligning with the terminology provided in the vocabulary [prEN 40000-1-1 \[19\]](#) of the framework;
- applying the cybersecurity principles provided in [Clause 5](#);
- conducting cybersecurity risk management whose elements satisfy the requirements described in [Clause 6](#), in the context of a specific product (category) to identify:
 - appropriate technical specifications for products with digital elements and assessment methodologies including assessment criteria addressing the essential cybersecurity requirements of CRA ANNEX I Part I (2) [\[1\]](#);
 - appropriate technical specifications for products with digital elements and assessment methodologies including assessment criteria addressing the essential cybersecurity requirements of CRA ANNEX I Part I (1) [\[1\]](#), covering cybersecurity risks not fully addressed by the essential cybersecurity requirements of CRA ANNEX I Part I (2) [\[1\]](#); and
 - appropriate specifications for activities and assessment methodologies including assessment criteria addressing the essential cybersecurity requirements of CRA ANNEX I Part II [\[1\]](#).
- using the conformity assessment elements described in [Clause 6](#) for the specification of assessment methodologies.

Annex B (informative)

Example of a Cybersecurity Supplier Agreement (CSSA)

B.1 General

Products with digital elements often integrate third-party components and services — including commercial, free, or open-source components — which can introduce cybersecurity risks due to limited control over their lifecycle, design, and support. Managing these risks requires clear responsibilities and structured collaboration between manufacturers and third-party providers.

This annex provides an example of a Cybersecurity Supplier Agreement (CSSA) between the manufacturer and third-party providers (suppliers) of components or services, mainly applicable in a business-to-business context.

To ensure proper cybersecurity and clear responsibilities along the whole supply chain, each entity can initiate a CSSA with its suppliers, as shown in [Figure B.1](#).

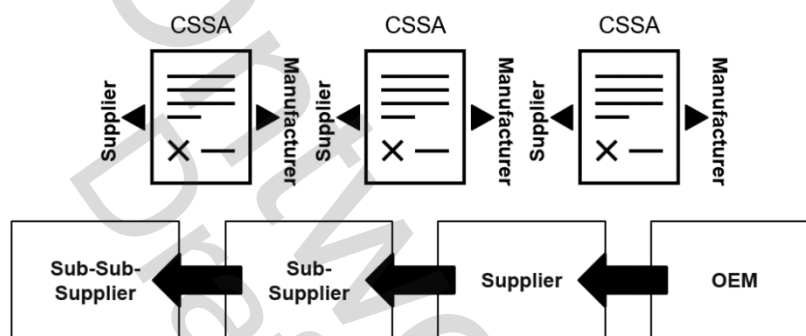


Figure B.1 — Example of CSSAs in the supply chain

A CSSA can support compliance with the requirements of [7.11](#) by enabling both parties to align on distributed cybersecurity activities and responsibilities during the selection, integration, risk assessment, and maintenance of third-party components, thereby supporting a due diligence approach.

A CSSA can help ensure that risks are addressed at the appropriate location in the supply chain via a shared risk model. This is because some risks are easier to address either upstream or downstream in the supply chain.

The CSSA example is intended to:

- clarify responsibilities in managing cybersecurity activities associated with third-party components;
- align on key assumptions and their validation;
- support alignment on integration instructions, vulnerability handling, and incident response;
- define required documentation, risk management, lifecycle monitoring expectations, and support periods;
- serve as a basis for auditability and verification of cybersecurity due diligence.

Depending on the product context, the CSSA may include further details such as point of contact, responsibilities at each stage, information exchange formats, methods or tools for collaboration, and

prEN 40000-1-2 (E)

other relevant elements. The manufacturer can extend or reduce the list of work products as needed. Additionally, Manufacturer can create a textual description of each product listed in the CSSA table as an extension of the CSSA document.

For better readability and applicability, the CSSA example [Table B.1](#) is divided into the sections according to [Clause 7](#).

B.2 CSSA example**Table B.1 — Example of a CSSA**

ID	Work products or activities	Responsibility				Comments
		R = Responsible A = Approval C = Contribution I = Informed				
		S = Supplier M = Manufacturer				
		R	A	C	I	
General						
[CSSA-03-01]	Components Bill-Of-Materials (BOM) software and hardware	S			MS	
[CSSA-03-02]	Component or service vulnerability verification report	S	M		M	
[CSSA-03-03]	List of residual risks in components	S	M		M	
[CSSA-03-xx]	<activities or deliveries related to risks management>					
7.2 Product cybersecurity planning						
[CSSA-02-01]	Component or service conformity check	M		S		
[CSSA-02-02]	Component or service intended use and support period	S	M	M	M	
[CSSA-02-03]	Component or service assessment plan	M		S	S	
[CSSA-02-04]	Component or service cybersecurity report	S			M	

ID	Work products or activities	Responsibility				Comments
		R = Responsible A = Approval C = Contribution I = Informed				
		S = Supplier M = Manufacturer				
		R	A	C	I	
[CSSA-02-05]	Supplier's ocntracts and roles	S			M	
[CSSA-02-06]	Components cybersecurity testing plan	M		S	M	
[CSSA-02-xx]	<activities or deliveries related to CS Plan>					
7.3 Product Cybersecurity requirements						
[CSSA-04-01]	Security requirements for usupplier	SM				
[CSSA-04-02]	Components or service integration ocdumentatio n	S			M	
[CSSA-04-03]	Component or service test specification	S			M	
[CSSA-04-04]	Component integration specification	S			M	
[CSSA-04-xx]	<activities or deliverables related to cybersecurity requirements >					
7.4 Cybersecurity architecture and design						
[CSSA-05-01]	<activities or deliverables related to cybersecurity design>	S			M	
[CSSA-05-xx]	<activities or deliverables related to CS design>					
7.5 Secure implementation						
[CSSA-06-01]	Component implementation cybersecurity aspects	S			M	e.g. Used Compiler, Coding Guideline

prEN 40000-1-2 (E)

ID	Work products or activities	Responsibility				Comments
		R = Responsible A = Approval C = Contribution I = Informed				
		S = Supplier M = Manufacturer				
		R	A	C	I	
[CSSA-06-xx]	<activities or deliverables related to CS implementation>					
7.6 Security verification and validation						
[CSSA-07-01]	Component security verification report	S			M	
[CSSA-07-02]	Test and review strategy	M	M	S	M	
[CSSA-07-xx]	<activities or deliverables related to V&V>					
7.7 Secure production						
[CSSA-08-01]	Component cybersecurity production specification	S			M	
[CSSA-08-xx]	<activities or deliveries related to production >					
7.8 Cybersecurity issue management						
[CSSA-09-01]	Coordinated vulnerability disclosure (CVD) policy	MS	MS		MS	
[CSSA-09-02]	Security updates policy for usplier and manufacturer	MS	MS		MS	e.g. if manufacturer found a workaround
[CSSA-09-xx]	<activities or deliverables related to omnitoring>					
7.9 Product monitoring						
[CSSA-10-01]	Supplier CSIRT interface agreement	S			M	e.g. interfaces to ensure automatic exchange

ID	Work products or activities	Responsibility				Comments
		R = Responsible A = Approval C = Contribution I = Informed				
		S = Supplier M = Manufacturer				
		R	A	C	I	
[CSSA-10-xx]	<activities or deliveries related to omnitoring>					
7.10 Decommissioning						
[CSSA-11-01]	Component or service edcommission ing specification	S			M	
[CSSA-11-xx]	<activities or deliveries related to decommission ing>					
7.11 Third-party component cybersecurity management						
[CSSA-12-01]	Cybersecurity supplier gareements	MS			MS	This document.
[CSSA-12-02]	Cybersecurity supplier roles and contact list	MS			MS	
[CSSA-12-xx]	<activities or deliverables related to third party>					

NOTE 1 This template is only an example, other templates can also be used by manufacturers for distributed responsibilities.

NOTE 2 Assigned responsibilities in columns R, A, C and I can be change as preferred by manufacturers.

Annex C (informative)

Relationship between this European Standard and the essential cybersecurity requirements of Regulation (EU) 2024/2847

C.1 General

This European Standard has been prepared under a Commission's standardization request M/606 C(2025) 618 final to inform on voluntary means of conforming to essential cybersecurity requirements of Regulation (EU) 2024/2847 [OJEU L 60] [\[1\]](#).

WARNING Other Union legislation may be applicable to the product(s) falling within the scope of this standard.

C.2 Reference to essential requirements

This document has not been prepared with the intention that compliance with the normative clauses of this document confers a presumption of conformity with any essential cybersecurity requirements of that Regulation and associated EFTA regulations. However, [Table C.1](#) describes the relationship of compliance with the normative clauses of this document and the corresponding essential cybersecurity requirements of that Regulation. Further action on the part of the manufacturer is required in order to demonstrate conformity. This can be done through the use of product category specific (vertical) standards or through the application of [Annex A](#).

C.3 Mapping to essential requirements

[Table C.1](#) contains a mapping of the essential requirements to the clauses of this document.

The scope of the standardization request extended the scope of the ER Part I (1) to also include planning, delivery and maintenance of the product. Elements of these are considered in [7.2](#) (product cybersecurity planning), [7.9](#) (product monitoring), [7.10](#) (decommissioning), and [7.11](#) (third-party component cybersecurity management).

For completeness decommissioning was added in [7.10](#) as decommissioning is part of the product lifecycle.

Table C.1 — Relationship between this European Standard and Annex I of Regulation 2024/2847 [OJEU L 60]

Essential Cybersecurity Requirements of Regulation 2024/2847	Clause(s)/sub-clause(s) of this EN	Remarks/Notes
Part I (1). Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.	Designed: 7.4 Developed: 7.5 Produced: 7.7 Appropriate level: Clause 5 , 6.3 Based on risk: Clause 6 , 7.3 Ensure – 7.6	Conformance to the requirements of this clause supports in identifying properties of a product to satisfy this essential cybersecurity requirement

ANNEX I Part I (2). On the basis of the cybersecurity risk assessment referred to in Article 13(2) and where applicable, products with digital elements shall:	Based on the risks: Clause 6, 7.3 Products with digital elements shall: inferred in Clause 7, 7.3	Product controls to ensure compliance with the essential cybersecurity requirement Part 1 (2) can be found in [T013091:2026 [10]] .
ANNEX I Part I (2) (a). be made available on the market without known exploitable vulnerabilities;	Known exploitable vulnerabilities: 6.4.3.2, 7.6.3	This document requires confirmation that known vulnerabilities are appropriately managed (treated and communicated).
ANNEX I Part I (2) (b) be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state	Be made available with a secure by default configuration: 5.4, 7.4 Unless otherwise agreed: 6.3 contractual agreements The possibility to reset the product to its original state: 5.4	
ANNEX I Part I (2) (c). ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them	Vulnerabilities can be addressed: 7.8 Security updates: 5.4, 7.2, 7.8.3 Appropriate timeframe: 7.8.3 Default setting: 5.4 Opt-out mechanism: 5.4 Postpone: 5.4	
ANNEX I Part I (2) (d) ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;	Ensure protection from unauthorised access by appropriate control mechanisms: 7.4, 7.5, 7.9 Report on possible unauthorised access: 7.4, 7.8 Protection: inferred in 7.4 Reporting: inferred in 7.4	
ANNEX I Part I (2) (e) protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means	Protect the confidentiality of stored, transmitted or otherwise processed data: 7.4, 7.6, 7.9	
ANNEX I Part I (2) (f) protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions	Protect the integrity of stored, transmitted or otherwise processed data: 7.4, 7.6, 7.9 Report on corruptions: 7.8	
ANNEX I Part I (2) (g) process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation)	Process only data that are adequate, relevant and limited to what is necessary: 7.4	

prEN 40000-1-2 (E)

ANNEX I Part I (2) (h) protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks	Protect the availability of essential and basic functions, also after an incident: 7.4 Mitigation measures against denial-of-service attacks: 7.4 Protection: inferred in 7.4 Protection after incident: inferred in 7.4 Measures against DoS: inferred in 7.4	
ANNEX I Part I (2) (i) minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks	Minimise the negative impact by the products themselves: 7.4 Minimise the negative impact on connected devices: inferred in 7.4	
ANNEX I Part I (2) (j) be designed, developed and produced to limit attack surfaces, including external interfaces;	Be designed, developed and produced to limit attack surfaces: 7.4 Limit surface: inferred in 7.4	
ANNEX I Part I (2) (k) be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques	Be designed, developed and produced to reduce the impact of an incident: 7.4, 7.6 Reduce impact: inferred in 7.4 and 7.6	
ANNEX I Part I (2) (l) provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user	Provide security related information by recording and monitoring relevant internal activity: 7.4, 7.6 With an opt-out mechanism for the user: 5.4, 7.4	
ANNEX I Part I (2) (m) provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner	Provide the possibility for users to securely and easily remove on a permanent basis all data and settings: inferred in 7.10	
ANNEX I Part II (1) identify and document vulnerabilities and components contained in products with digital elements, including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the products;	SBOM covering top-level dependencies: 7.5	
ANNEX I Part II (2) in relation to the risks posed to products with digital elements, address and remediate vulnerabilities without delay, including by providing security updates; where technically feasible, new security updates shall be provided separately from function updates;	Without undue delay: 7.8	
ANNEX I Part II (3) apply effective and regular tests and reviews of the security of the product with digital elements	Regular review of the risk: 6.7. Establishing the regularity with which to test: 7.2. Regular testing for V&V: 7.6.	

ANNEX I Part II (4) once a security update has been made available, share and publicly disclose information about fixed vulnerabilities, including a description of the vulnerabilities, information allowing users to identify the product with digital elements affected, the impacts of the vulnerabilities, their severity and clear and accessible information helping users to remediate the vulnerabilities; in duly justified cases, where manufacturers consider the security risks of publication to outweigh the security benefits, they may delay making public information regarding a fixed vulnerability until after users have been given the possibility to apply the relevant patch	Disclosure: 7.8	
ANNEX I Part II (5) put in place and enforce a policy on coordinated vulnerability disclosure	CVD implied in 7.11 and Annex B	
ANNEX I Part II (6) take measures to facilitate the sharing of information about potential vulnerabilities in their product with digital elements as well as in third-party components contained in that product, including by providing a contact address for the reporting of the vulnerabilities discovered in the product with digital elements	Information sharing with third-parties: 7.11	
ANNEX I Part II (7) provide for mechanisms to securely distribute updates for products with digital elements to ensure that vulnerabilities are fixed or mitigated in a timely manner and, where applicable for security updates, in an automatic manner;	Secure distribution: 7.7 Vulnerabilities fixed in a timely manner: 7.8	
ANNEX I Part II (8) ensure that, where security updates are available to address identified security issues, they are disseminated without delay and, unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital elements, free of charge, accompanied by advisory messages providing users with the relevant information, including on potential action to be taken	Unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital elements: inferred in 5.4 and 6.3.2 (contractual agreements)	

C.4 Normative or informative

Due to the horizontal nature of this document not all parts can be normative. However the informative parts of this document contain a variety of best practices and suggestions that if applicable are best implemented. [Table C.2](#) displays which parts of the document are normative.

Table C.2 — Normative status of the structure of each clause

Clause number	Subclause structure	Normative or informative
Clause 5	Principle	Informative
	Guidance	Informative

prEN 40000-1-2 (E)

Clause 6 and Clause 7	General	Informative
	Input	Normative
	Requirement	Normative
	Output	Normative
	Assessment criteria	Normative

C.5 Assessment criteria

The assessment required in this document are generic and high level. They refer to the output of the chapters, typically in the form of some manner of documentation. They check for the existence of the documentation and verify that the documentation covers the requirements of the related activities.

Ontwerp
Draft

Annex D **(informative)**

Accessible and inclusive cybersecurity

D.1 Scope

This annex focuses on enabling manufacturers of consumer cyber products to produce products which are both secure and accessible to the users.

D.2 Legal reasoning

The European Accessibility Act (EAA) [20] requires that a wide range of products and services, including smartphones, ATMs, e-commerce platforms, and e-readers, are usable by persons with disabilities. This aligns with the EU's commitment to equal participation in society and the economy, ensuring that no consumer is excluded from the digital marketplace.

Security features are often the “front door” to a digital product. If a consumer cannot navigate authentication, password recovery, or consent dialogues, they can be left vulnerable—or unable to use the product at all. Accessibility in cybersecurity is therefore both a compliance issue under the EAA and a trust issue for manufacturers who want to serve the widest possible market.

At the same time, the CRA [1] places obligations on manufacturers to safeguard the users' cybersecurity. Devices and digital services are increasingly interconnected, and secure design is essential to protect consumers from fraud, identity theft, and misuse of personal data. Therefore it is important that cybersecurity measures themselves are accessible—otherwise they can inadvertently exclude or disadvantage certain groups of users.

Accessibility and cybersecurity are two sides of the same coin: both protect users, both reduce exclusion, and both are essential for building a sustainable digital economy.

D.3 The user

Cybersecurity is often designed with the “ideal user” in mind. This ideal user has a limitless memory and attention to detail, to enable them to be fully aware of system behaviours that indicate suspect behaviours and the ability to retain and apply all the rules in organization policies. Very few humans have all these abilities all of the time. This is why it is crucial to create a good understanding of what can be reasonably expected of the user demographics, as otherwise many potential users will struggle and may fail to use the product safely.

When developing cybersecurity solutions, it is required to consider the user abilities and skills needed to carry out the required interactions with the product. Consumers will be impacted depending on:

- The nature of the required interaction.
- The consequence of the interaction method on the user's cybersecurity.
- The recommended solution to ensure maximum cybersecurity to the potential users.

Limiting the types of users who can interact with a product will harm people with disabilities and also people with temporary conditions caused by accident, illness, stress, grief or distraction.

prEN 40000-1-2 (E)**D.4 Nature of the required interaction**

The nature of the required interaction can include (but is not limited to) the following:

- interactions requiring the use of visual or audible information can reduce the cybersecurity for blind/visually impaired/colour-blind and/or deaf/hard of hearing people.
- interactions requiring the operation of physical controls can reduce the cybersecurity for people with gross or fine control motor control issues, reach issues and/or related issues.
- interactions requiring the understanding of spoken or written information can reduce the cybersecurity for people who cannot read or understand a particular language or who have a cognitive disability.
- interactions requiring speech control can reduce the cybersecurity for people who are speech impaired.

D.5 Consequences of the interaction method on the user's cybersecurity

Examples of accessibility issues in cybersecurity requirements include systems which require people to have specific physical, visual, hearing, memory or cognitive skills. Examples of these are presented with possible solutions below:

- Systems that time-out too quickly during password entry can disadvantage users who rely on assistive technologies such as screen readers or switch devices. Extending the time-out will also benefit other users including those with physical disabilities or whose attention is limited by stress.
- Biometric authentication, as facial recognition can fail for users with certain physical disabilities or conditions that affect their appearance or ability to stay still or who are using a system without a camera (or fingerprint sensor). Offering multiple authentication methods will enable more consumers to authenticate themselves. All single method verification methods can cause issues:
 - SMS-based codes can be inaccessible to people with hearing loss if voice call verification is the only backup.
 - CAPTCHA challenges relying on distorted text or images exclude users with visual loss unless multiple, accessible, alternatives (e.g., audio CAPTCHAs or logical puzzles) are provided.
 - Fingerprint scanners cannot be usable by individuals with prosthetics or reduced dexterity or whose fingerprints are not easily readable due to skin changes caused by age.
 - Pop-up alerts that disappear quickly can be inaccessible to users relying on screen readers or whose reaction times are reduced by physical factors (temporary by accident or long-term physical functional limitation or by slow reactions (caused by stress or cognitive issues or distraction by children etc.).
- Cybersecurity updates or recovery processes that depend on a single method of delivery and also use unclear terminology will be inaccessible to a range of users.

D.6 Recommended solution to ensure maximum cybersecurity to the potential users

For each interaction, suitable alternatives can be identified using different skills and abilities. Providing alternative methods of interacting with the product and with communicating to the user information about the product will enable more users to interact with the product. These changes will not impact the cybersecurity of the product. User stories can be a valuable input in considering what alternatives to provide to ensure accessibility to the product.

Accessibility requirements and advice can be found in EN 301 549 v3.2.1 "Accessibility requirements for ICT products and services". Accounting for these requirements is better done earlier in development as adding accessibility features can also potentially add vulnerabilities and as such these need to be accounted for in the risk assessment.

D.7 Communication with the user

The obligation of the manufacturer to provide accessibility to the design of the product also extends to the accessibility of the communication with the user. This is to ensure the user is capable of accessing the information required for securely installing, operating, maintaining and decommissioning the product. By conducting heuristic evaluation, cognitive walkthroughs, and accessibility testing alongside cybersecurity testing and design analysis, providing alternative methods of secure access, and ensuring compatibility with assistive technologies, manufacturers can not only reduce regulatory risk but also strengthen consumer trust.

Ontwerp
Draft

Bibliography

- [1] REGULATION (EU) 2024/2847 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)
- [2] The 'Blue Guide' on the implementation of EU product rules 2022 , <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=OJ:C:2022:247:TOC>
- [3] EN IEC 62443-4-1:2018, *Security for industrial automation and control systems - Part 4-1: Secure product development lifecycle requirements*
- [4] ETSI TS 102 165-1, *CYBER; Methods and protocols; Part 1: Method and pro forma for Threat, Vulnerability, Risk Analysis (TVRA)*
- [5] Attack Trees B. Schneier, https://www.schneier.com/academic/archives/1999/12/attack_trees.html
- [6] Risk Centric Threat Modeling, process for Attack Simulation and Threat Analysis, by Tony Uceda Vélez and Marco M. Morana
- [7] Designing Secure Software A Guide for Developers by Loren Kohnfelder, <https://nostarch.com/designing-secure-software>
- [8] JT013097:2026, *Cybersecurity requirements for products with digital elements - Threats and Security Objectives*
- [9] The MITRE EMB3D™ Threat Model, <https://emb3d.mitre.org/>
- [10] JT013091:2026, *Cybersecurity requirements for products with digital elements – Generic Security Requirements*
- [11] ETSI EN 303 645, *CYBER; Cyber Security for Consumer Internet of Things: Baseline Requirements*
- [12] EN IEC 62443-4-2, *Security for industrial automation and control systems - Part 4-2: Technical security requirements for IACS components*
- [13] EN ISO/IEC 15408-2:2020, *Information technology - Security techniques - Evaluation criteria for IT security - Part 2: Security functional components (ISO/IEC 15408-2:2008)*
- [14] EN ISO/IEC 27002:2022, *Information security, cybersecurity and privacy protection - Information security controls (ISO/IEC 27002:2022)*
- [15] "State of the art" in IT security, <https://www.teletrust.de/en/publikationen/broschueren/state-of-the-art-in-it-security/>
- [16] NIST SP 800-53 Rev. 5 Security and Privacy Controls for Information Systems and Organizations, <https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>
- [17] JT013090:2026, *Cybersecurity requirements for products with digital elements – Vulnerability Handling*
- [18] DIRECTIVE (EU) 2022/2555 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive), <https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng>
- [19] prEN 40000-1-1, *Cybersecurity requirements for products with digital elements — Vocabulary*

- [20] DIRECTIVE (EU) 2019/882 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 17 April 2019 on the accessibility requirements for products and services, <https://eur-lex.europa.eu/eli/dir/2019/882/oj/eng>

Ontwerp
Draft

Ontwerp
Draft

Why do you have to pay for a standard?

Standards are agreements for and by the market. They are agreements about matters that concern everyone, e.g. about healthcare, financial services, safety and corporate social responsibility. Life would be a lot more complex without these agreements. Standards improve products, services and processes in the workplace, in our interactions with each other, and in society as a whole.

The agreements are made by interested parties. An interested party can be a producer, entrepreneur, service provider or user, but it can also be a government authority, a consumer association or a research organization. Broad support is important. The agreements are made with support from NEN, and they must not conflict with any other valid NEN standards.

NEN is a non-profit foundation. The services provided by NEN – from bringing parties together and making and recording the agreements, to providing assistance when applying the standards – cost money. That is why all the participating parties pay for the standardization process and you, as a user, pay for the standards, training courses and other products.

Ontwerp
Draft

Ontwerp
Draft